

RELATÓRIO DE AUDITORIA DE SEGURANÇA

GeoAlerta — Gabinete de Crise Integrado

Data da Auditoria: 13 de Setembro de 2026

Escopo Auditado: Código-fonte Next.js, esquemas Supabase SQL, storage, middleware e rotas do painel

Mapeamento da Stack Tecnológica:

- Linguagem & Runtime:** TypeScript / Node.js v24
- Framework Frontend & Backend:** Next.js 16.3.5 (App Router, Turbopack, React 19)
- Banco de Dados & Storage:** Supabase PostgreSQL com extensão geográfica PostGIS e Supabase Storage
- Mecanismo de Autenticação:** Supabase Auth (@supabase/ssr + @supabase/supabase-js) com sessão em cookies
- Deploy & Infraestrutura:** Vercel Edge / Serverless, sem containers Docker ativos

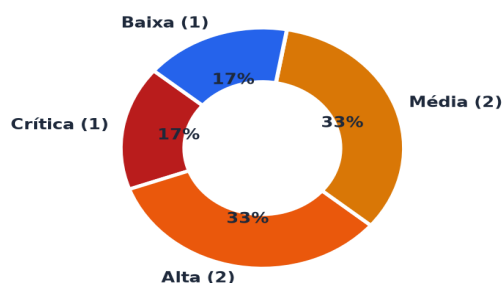
Nota Metodológica:

A auditoria foi executada com base no rigoroso protocolo das **Cinco Falhas Capitais de Segurança**: (1) Banco sem Tranca (RLS e isolamento de dados no Supabase); (2) Permissão no Navegador (gates de UI vs validação server-side); (3) IDOR (manipulação arbitrária de ocorrências por UUID); (4) Chaves Expostas (verificação de segredos e histórico git); (5) Inputs sem Tratamento (validação de payloads e vetores de upload XSS).

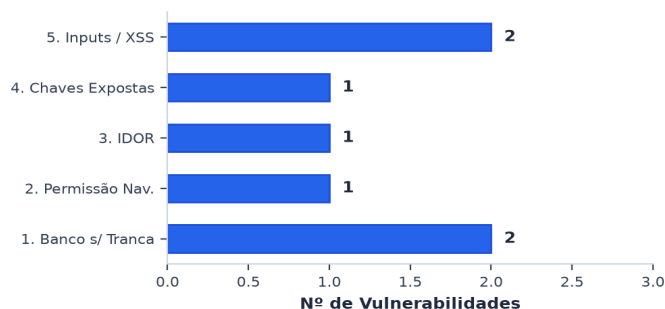
1. Resumo Executivo

Foram detectadas **6 vulnerabilidades verificadas no código real** (1 Crítica, 2 Altas, 2 Médias, 1 Baixa). O sistema possui pontos fortes estruturais modernos, como o middleware Server-Side de autenticação e proteção nativa do React contra XSS refletido. No entanto, o acesso direto do cliente ao banco de dados via Supabase com políticas RLS excessivamente permissivas (`USING true`) representa o risco mais crítico.

Vulnerabilidades por Severidade



Achados por Categoria



2. Pontos Fortes e Riscos Centrais

■ Pontos Fortes Verificados no Código:

- **[CONFIRMADO] Proteção Server-Side das Rotas do Pannel:** O arquivo `src/middleware.ts` valida ativamente a sessão no servidor via `supabase.auth.getUser()` para toda a rota `/painel/*`, impedindo acesso não autorizado.
- **[CONFIRMADO] Histórico Git 100% Limpo:** Nenhum arquivo de variáveis de ambiente (`.env`) foi commitado no histórico do repositório.
- **[CONFIRMADO] Sem Secrets em Código:** A biblioteca `lib/supabase.ts` consome exclusivamente variáveis de ambiente, sem chaves embutidas em código.
- **[CONFIRMADO] Escaping Nativo contra XSS:** Os componentes React interpolam dados de relatores e descrições sem utilizar `dangerouslySetInnerHTML`.

■ Riscos Centrais Identificados:

- **[CRÍTICO] RLS Aberto para Modificações:** A policy de UPDATE da tabela `occurrences` permite que qualquer cliente anônimo com a `anon key` altere registros de qualquer chamado.
- **[ALTO] Upload de Mídia sem Lista Branca:** A extensão e tipo MIME dos arquivos de foto são extraídos diretamente do nome fornecido pelo usuário sem sanitização ou limite de tamanho.

3. Tabela de Achados Detalhados por Categoria

Severidade	Arquivo : Linha	Descrição da Vulnerabilidade & Categoria
CRÍTICA	supabase.sql:41-42	[1. Banco s/ Tranca] Policy Permitir alteração anônima usa FOR UPDATE USING (true). Qualquer pessoa na internet pode alterar status ou apagar informações de chamados via API aberta sem login.
ALTA	sistema/src/app/page.tsx:55-61	[5. Inputs / XSS] Upload extrai <code>file.name.split('.').pop()</code> sem validar lista branca de extensões (jpg, png) nem validar tamanho máximo, permitindo upload de scripts ou arquivos gigantes.

ALTA	sistema/src/app/painel/page.tsx:99 tabela/page.tsx:109	[3. IDOR] Updates de ocorrência operam diretamente por ID sem validar propriedade de órgão ou contexto de autorização da requisição no banco.
ALTA	supabase.sql:49-50	[1. Banco s/ Tranca] Storage Policy de insert aberta sem limite de cota de upload por IP ou checagem de tipos MIME aceitos no bucket.
MÉDIA	sistema/src/middleware.ts:38-44	[2. Permissão Nav.] Middleware valida autenticação, mas não valida papéis/órgãos (RBAC). Qualquer servidor logado tem acesso irrestrito a botões de despacho de outros órgãos.
BAIXA	sistema/.env:4-5	[4. Chaves Expostas] Arquivo local contém senha mestra do PostgreSQL em texto puro. Embora protegido pelo .gitignore, requer rotação e cofre de segredos em produção.

4. Recomendações Priorizadas de Correção

P1 (Imediata) — Trancar Políticas de UPDATE no Supabase

Remova a policy Permitir alteração anônima e restrinja a operação de UPDATE exclusivamente a usuários autenticados: CREATE POLICY 'Apenas gestores alteram' ON public.occurrences FOR UPDATE USING (auth.uid() IS NOT NULL);

P2 (Alta) — Sanitização Estrita de Uploads de Mídia

No arquivo src/app/page.tsx, valide o tipo MIME (permitir apenas image/jpeg, image/png, image/webp) e limite o tamanho a no máximo 5MB antes do upload. Gere o nome do arquivo com UUID v4 criptográfico em vez de concatenar a extensão enviada pelo cliente.

P3 (Média) — Implementar RBAC e Perfis de Órgãos

Criar tabela de perfis de gestores vinculada a auth.users para registrar o órgão de lotação (ex: Defesa Civil, Bombeiros, Obras, Assistência) e limitar o despacho de acordo com o órgão correspondente.

5. Issues Acionáveis para o GitHub

Copie os blocos delimitados abaixo diretamente para a aba de Issues do seu repositório:

[Segurança] Restringir Políticas de UPDATE na tabela occurrences (RLS)

Labels: security, crítica, supabase

--- ISSUE 1 ---

Título: [Segurança] Restringir Políticas de UPDATE na tabela occurrences (RLS)

Labels: security, crítica, supabase

Descrição:

A policy atual de UPDATE na tabela `public.occurrences` está configurada com `FOR UPDATE USING (true)`. Isso permite que qualquer cliente anônimo com a anon key consiga alterar dados ou apagar ocorrências via API aberta.

Evidência:

supabase.sql (linhas 41-42):

```
CREATE POLICY "Permitir alteração anônima" ON public.occurrences FOR UPDATE USING (true);
```

Impacto:

Adulteração de relatórios da Defesa Civil, encerramento indevido de chamados de resgate e falsificação de despachos operacionais.

Sugestão de Correção:

Substituir a policy por:

```
CREATE POLICY "Permitir apenas gestores autenticados alterarem" ON public.occurrences FOR UPDATE USING (auth.uid() IS NOT NULL);
```

Critérios de Aceite:

- [] Drop da policy 'Permitir alteração anônima'.
- [] Criação de nova policy exigindo sessão autenticada.
- [] Teste de update anônimo via REST confirmando bloqueio (403/0 rows).

--- FIM ISSUE 1 ---

[Segurança] Sanitizar upload de evidências fotográficas e limitar tamanho

Labels: security, alta, storage

--- ISSUE 2 ---

Título: [Segurança] Sanitizar upload de evidências fotográficas e limitar tamanho

Labels: security, alta, storage

Descrição:

O formulário de registro de ocorrência do cidadão extrai a extensão do arquivo diretamente de `file.name` e realiza upload no Supabase Storage sem validação de tipos MIME ou tamanho máximo.

Evidência:

```
sistema/src/app/page.tsx (linhas 55-61):  
const fileExt = file.name.split('.').pop();  
const fileName = `${Math.random()}.${fileExt}`;
```

Impacto:

Risco de upload de scripts maliciosos (.html, .svg com JS), esgotamento de quota do Storage (DDoS de armazenamento) ou arquivos corrompidos.

Sugestão de Correção:

- Validar se `file.type` está na lista `['image/jpeg', 'image/png', 'image/webp']`.
- Rejeitar arquivos com mais de 5MB.
- Gerar nome utilizando `crypto.randomUUID()` com extensão fixa determinada pelo MIME type.

Critérios de Aceite:

- [] Validação de tamanho (< 5MB) antes do envio.
- [] Validação estrita de tipo de imagem.
- [] Nome do arquivo seguro sem caracteres controlados pelo cliente.

--- FIM ISSUE 2 ---

[Segurança] Implementar controle de acesso por órgão (RBAC)

Labels: security, média, auth

--- ISSUE 3 ---

Título: [Segurança] Implementar controle de acesso por órgão (RBAC)

Labels: security, média, auth

Descrição:

Atualmente, qualquer usuário autenticado no painel pode atualizar e despachar ocorrências de qualquer órgão sem restrição de papel (ex: operador de obras alterando chamados de bombeiros).

Evidência:

```
sistema/src/app/painel/page.tsx (linha 99) e sistema/src/middleware.ts:  
Verificação limita-se à existência de user, sem checar role ou orgao.
```

Impacto:

Falta de rastreabilidade de ações e conflito de despachos operacionais entre secretarias municipais.

Sugestão de Correção:

Vincular metadados de órgão ao usuário no Supabase Auth (`raw_user_meta_data.orgao`) e validar a correspondência antes de permitir o despacho.

Critérios de Aceite:

- [] Tabela ou metadata de usuários com órgão vinculado.
- [] Bloqueio de ações em ocorrências de outros órgãos, exceto para perfil Administrador.

--- FIM ISSUE 3 ---